

Capítulo 10

Ignorando Proteções

10.1. Objetivos

- Conhecer os mecanismos de evasão de firewall
- Conhecer as técnicas de evasão de IDS/IPS
- Entender as técnicas de anti-forense

10.2. Evasão de Firewall/IDS com Nmap

As técnicas de evasão de firewall e IDS são utilizadas para evitar que qualquer tipo de aplicação que contenha filtros e controles de acesso, possam detectar as ações do atacante.

Tanto ferramentas específicas quanto parâmetros de ferramentas cujo objetivo de utilização não é especificamente esse, podem ser usados.

Abaixo vamos ver alguns parâmetros do Nmap, que podem ser utilizados para burlar proteções, e do Firewall Tester (FTester), que é utilizado para testar regras de firewall pesquisando como está o nível de bloqueio e detecção de pacotes maliciosos.

- **-f** => fragmenta pacotes, incluindo pacotes IP. A idéia é dividir os cabeçalhos TCP em vários pacotes, dificultando a detecção por filtros de pacotes, IDS e etc.
- **-D <decoy1>[,<decoy2>][,ME][...]** => realiza uma varredura utilizando iscas. Faz parecer que vários hosts da rede, juntamente com seu IP, estão varrendo o alvo. Desse modo, o IDS pode reportar 5-10 varreduras em um único IP, mas não saberá definir quais são iscas inocentes e qual IP está realmente realizando a varredura.
- **-S <IP_Address>** => realiza um IP spoofing, fazendo com que um IDS report uma varredura sendo realizada a partir de um outro IP, que não o seu, mas que é definido por você.
- **--source-port <portnumber>** => realiza um port spoofing, permitindo que seja definido no pacote de qual porta ele teoricamente foi enviado. Essa técnica explora as portas abertas no alvo para realizar varreduras que o firewall permitirá por conta de suas regras. As portas mais utilizadas são DNS (53) e FTP (21).
- **--randomize-hosts** => ordena de forma aleatória os hosts alvos de uma varredura. Isso pode tornar a varredura menos óbvia para sistemas de

monitoramento de rede, especialmente se combinado com opções de "slow timing".

- **--spoof-mac <MAC address>** => faz um MAC spoofing, atribuindo um endereço MAC, definido pelo atacante, para todos os frames ethernet enviados.

10.3. Firewall Tester

Firewall Tester (FTester) é uma ferramenta criada para testar regras de filtragem firewalls e as capacidades Intrusion Detection System (IDS).

A ferramenta consiste em 2 scripts perl, um injetor de pacotes (ftest) e um sniffer passivo (listening sniffer – ftestd).

10.3.1. Características:

- firewall testing
- IDS testing
- Simulação de conexões reais TCP para inspecionar firewalls e IDS.
- Fragmentação de IP / Fragmentação de TCP
- Técnicas de evasão de IDS

Download - <http://dev.inversepath.com/ftester>

Documentação - <http://dev.inversepath.com/ftester/ftester.html>

10.3.2. Utilização:



```
# ./ftest  
# ./ftestd
```

10.3.3. Sintaxe:

- Para pacotes TCP e UDP:

IP_origem:porta_origem:IP_destino:porta_destino:Flags:Protocolo:Tipo_serviço

- Para pacotes ICMP:

IP_origem:porta_origem:IP_destino:porta_destino:Flags:ICMP:tipo_icmp:código_icmp

Exemplo:

192.168.0.1:1-1024:10.7.0.1:20-25:S:TCP:22

10.4. Detectando Honeypots

Difícilmente uma organização ou empresa que esteja contratando profissionais para realizar um pentest, possui um honeypot em sua rede. Mas ainda assim existe essa possibilidade...

Existem vários tipos de honeypots, mas podemos dividi-los, basicamente, em dois grandes grupos:

- Honeypot de baixa interatividade
- Honeypot de alta interatividade

O honeypots de baixa interatividade são facilmente detectáveis, bastando utilizar boas ferramentas de varredura, descoberta de vulnerabilidades e exploração, pois por sua limitação de respostas e interação com o atacante, pelas respostas transmitidas ao atacante, esse último conseguirá perceber que o alvo não é uma máquina real.

Já com os honeypots de alta interatividade, a coisa muda de figura, pois suas

respostas são mais consistentes e o comportamento é bem próximo de um servidor real, caso esteja bem configurado.

Com os HP de alta interatividade, apenas a experiência e o conhecimento dessas armadilhas podem permitir ao pen-tester descobrir e detectar essas armadilhas para invasores. No entanto, não aconselho perder muito tempo tentando detectar honeypots e definir se um servidor que está tentando explorar é um HP ou não. Deixe que isso seja consequência de seu trabalho, e não o objetivo principal.

Três ótimas ferramentas que podem ser utilizadas na detecção de honeypots são:

- Nmap
- Nessus
- OpenVAS

10.5. Prática dirigida

Varredura com Spoofing e Decoy:



```
nmap -S 192.168.0.1 -p 22 -O -sV -P0 -n 192.168.200.1  
nmap -sS --source-port 53 -p 80 -P0 -n -D 192.168.0.24, 192.168.0.25  
192.168.200.x
```

1. Realizar essas varreduras nos micros vizinhos, com o wireshark rodando.
2. Descobrir, na rede, qual o IP onde há um honeypot sendo executado.

10.6. Contramedidas

- Manter regras de firewall e IDS muito bem configuradas
- Manter a atenção constante em logs de equipamentos que são responsáveis pela proteção da rede
- Não confiar em apenas um firewall ou IDS, compartimentalizando a rede